

OPERATION IRON FOREST

Reporte Ejecutivo de Red Team

Clasificación:	CONFIDENCIAL — Uso educativo
Adversario simulado:	APT28 (Fancy Bear) — GRU Rusia
Objetivo:	attackcorp.local — Domain Controller
Fecha:	28-29 Mayo 2026
Operador:	Adrián Camacho
Estado:	COMPLETADO — 8/8 Fases

1. Resumen Ejecutivo

IRON FOREST demostró que el dominio **attackcorp.local** puede comprometerse al 100% partiendo de una cuenta de usuario estándar, sin explotar vulnerabilidades de software y sin técnicas de fuerza bruta. El vector principal fue la combinación de un share SMB mal configurado con credenciales en texto claro y una ACL misconfiguration que otorgaba privilegios de WriteDACL sobre el objeto dominio a una cuenta no privilegiada.

El ataque completo desde credencial inicial hasta Domain Admin duró menos de 2 horas de operación activa. Todos los hashes NTLM del dominio fueron extraídos via DCSync sin necesidad de ser Domain Admin, utilizando únicamente permisos ACL mal configurados.

Attack Path

Paso	Técnica	Resultado
1	Credential Hunting — Share IT-Scripts	4 credenciales en texto claro
2	PS History via C\$ (backup_svc)	fin.garcia:Finance2024! + DA:NuevaPassword2026!
3	Overpass-the-Hash (fin.garcia)	TGT Kerberos válido 10 horas
4	WriteDACL Abuse (dacledit)	DCSync rights añadidos al dominio
5	DCSync (secretsdump)	13 hashes NTLM volcados incl. Administrador + krbtgt
6	ADIDNS + Responder	NTLMv2 backup_svc capturado via WPAD
7	C2 Sliver (iron_forest_dc01)	Beacon persistente en DC-01 como DA
8	Cleanup OPSEC	DCSync rights eliminados, WPAD tombstoned

2. Crown Jewels Capturados

#	Objetivo	Resultado	Impacto
1	Credenciales IT Scripts	4 creds en texto claro	Alto
2	Historial PS Administrador	Finance2024! + NuevaPassword2026!	Crítico
3	TGT Kerberos fin.garcia	fin.garcia.ccache válido 10h	Alto
4	DCSync rights via WriteDACL	DS-Replication-Get-Changes activo	Crítico
5	Hash NTLM Administrador	bc3abc2e0673a58e9e559d415b56d69d	Crítico
6	Hash NTLM krbtgt	d5237a2e43cb315c90679e2a5dae34ad	Crítico
7	NTLMv2 backup_svc (WPAD)	Hash capturado via Responder	Alto
8	Beacon C2 en DC-01	iron_forest_dc01 — ATTACKCORP\Administrador	Crítico

3. Fases de la Operación

Fase 01 — Reconnaissance [T1087.002]

BloodHound CE v9.1.0 + SharpHound v2.5.9 recolectaron 358 objetos del dominio. Query Cypher confirmó: fin.garcia → WriteDacl → ATTACKCORP.LOCAL. Attack path identificado: WriteDACL → DCSync → DA sin ser administrador.

Fase 02 — Credential Hunting [T1552.001 / T1039]

Share \\DC-01\\IT-Scripts accesible por todos los usuarios del dominio. backup_database.ps1 y deploy_webapp.ps1 contenían 4 credenciales en texto claro. ConsoleHost_history.txt del Administrador accesible via C\$ con backup_svc — contenía Finance2024! y NuevaPassword2026!.

Fase 03 — Overpass-the-Hash [T1550.003]

impacket-getTGT convirtió fin.garcia:Finance2024! en TGT Kerberos válido (10h). Kerberos sobre NTLM — menos detectable en entornos modernos.

Fase 04 — WriteDACL Abuse [T1222]

impacket-dacledit añadió DS-Replication-Get-Changes + DS-Replication-Get-Changes-All sobre DC=atackcorp,DC=local con la cuenta fin.garcia. Verificado: ACE[15] + ACE[19] en la DACL del dominio.

Fase 05 — DCSync [T1003.006]

impacket-secretsdump ejecutó DCSync con fin.garcia (cuenta no privilegiada). 13 hashes NTLM volcados incluyendo Administrador y krbtgt. Dominio atackcorp.local comprometido al 100%.

Fase 06 — ADIDNS Abuse [T1557.001]

dnstool.py creó registro wpad.atackcorp.local → 10.0.2.9. DNS Global Query Block List desactivado en DC-01. Responder capturó NTLMv2 de backup_svc via WPAD poisoning.

Fase 07 — C2 Establishment [T1071.001]

Sliver beacon iron_forest_dc01 desplegado en DC-01 como ATTACKCORP\Administrador. Beacon HTTP con symbol obfuscation. Check-in confirmado.

Fase 08 — Cleanup OPSEC [T1070]

DCSync rights eliminados via dacledit -action remove. Registro WPAD tombstoned via dnstool.py. Beacon y binario eliminados del disco en DC-01.

4. MITRE ATT&CK; Coverage

Táctica	Técnica	ID	Estado
Discovery	Account Discovery — Domain	T1087.002	■
Collection	Data from Network Shared Drive	T1039	■
Credential Access	Credentials in Files + PS History	T1552.001	■
Lateral Movement	Overpass-the-Hash	T1550.003	■
Privilege Escalation	WriteDACL Abuse	T1222	■
Credential Access	DCSync	T1003.006	■
Credential Access	LLMNR/WPAD Poisoning	T1557.001	■
Command & Control	Sliver HTTP Beacon	T1071.001	■
Defense Evasion	Indicator Removal	T1070	■

5. Hallazgos Críticos y Recomendaciones

H-01 — Share SMB con credenciales accesible por todos los usuarios [CRÍTICO]

Descripción: El share \\DC-01\IT-Scripts otorga ReadAccess a 'Usuarios del dominio', exponiendo scripts con credenciales en texto claro a cualquier cuenta comprometida.

Recomendación: Restringir acceso al grupo IT-Admins. Migrar credenciales a un secrets vault (CyberArk/Vault).

H-02 — ACL misconfiguration: WriteDACL sobre objeto dominio [CRÍTICO]

Descripción: fin.garcia tiene WriteDACL sobre DC=atackcorp,DC=local, permitiendo añadir derechos de replicación sin ser Domain Admin.

Recomendación: Auditar ACLs del objeto dominio periódicamente. Implementar alertas en Event ID 5136.

H-03 — Historial PowerShell con contraseña DA en texto claro [CRÍTICO]

Descripción: ConsoleHost_history.txt del Administrador accesible via C\$ contiene la contraseña del Domain Admin en texto claro.

Recomendación: Deshabilitar historial PS en sistemas sensibles: Set-PSReadLineOption -HistorySaveStyle SaveNothing.

H-04 — ADIDNS permite crear registros a usuarios autenticados [ALTO]

Descripción: Cualquier usuario autenticado puede crear registros DNS en la zona del dominio, permitiendo WPAD poisoning y captura de hashes NTLMv2.

Recomendación: Restringir creación de registros DNS a administradores DNS. Mantener DNS Global Query Block List activo.

6. Lecciones Aprendidas (selección)

L-01: SharpHound desde sesión Evil-WinRM requiere credenciales explícitas (--ldapusername/--ldappassword) porque el contexto WinRM no propaga Kerberos a procesos hijos.

L-02: BloodHound CE 5.x requiere Neo4j 4.4 con APOC. Neo4j 5 genera error 'db.indexes procedure not found'.

L-03: Los ZIPs de bloodhound-python legacy no importan correctamente en BloodHound CE 5.x — usar SharpHound.

L-04: Responder, BloodHound CE Docker y Sliver HTTP compiten por el puerto 80. Orden correcto: parar Docker → Responder → obtener hash → parar Responder → Sliver listener.

L-05: DNS Global Query Block List bloquea resolución de 'wpad' por defecto en Windows Server 2022. Desactivarlo genera Event ID 5136 — detectable.

L-06: Invoke-WebRequest -UseDefaultCredentials desde WinRM no propaga credenciales NTLM. Usar System.Net.WebClient con credenciales explícitas.

L-07: dacledit genera backup automático .bak de la DACL — útil para restaurar exactamente.

L-08: Matar proceso externo en puerto 80 no libera el job en Sliver — requiere systemctl restart sliver.